SLIDE PACK

# Module C: Background information gathering and open source

1 units, 24 slides.



MY CYBER ACADEMY

Unit U05

CREST Practitioner Intrusion Analyst (CPIA)

# Background Information Gathering & Open Source

WHOIS, DNS, open-source investigation, document metadata and community knowledge.

GROUP C | OSINT | BACKGROUND INFORMATION




© Billy Forrest

# Five skill areas, one open-source picture

| Ref | Skill area | Focus |
|---|---|---|
| C1 | Registration Records | WHOIS — IP and domain registries |
| C2 | Domain Name Server (DNS) | Records, zone transfers, dynamic DNS, fast-flux |
| C3 | Open Source Investigation & Web Enumeration | Search engines, online sources, theHarvester |
| C4 | Extraction of Document Metadata | Hidden data inside files |
| C5 | Community Knowledge | Threat reports, resources, false positives |



© Billy Forrest

UNIT OBJECTIVES

# By the end of this unit you will be able to

- **Read registration records** WHOIS information on IP addresses and domains
- **Interpret DNS records** A, CNAME, NS, SOA, MX, TXT, PTR, HINFO
- **Explain zone transfers and fast-flux** and the security implications of dynamic DNS
- **Conduct open-source investigation** search engines, directories, people search, archives, social media
- **Extract document metadata** and understand the risks it exposes
- **Use community knowledge** threat reports, security resources, and eliminate false positives


© Billy Forrest

# What are registration records?

- **Stored in the WHOIS database** information about IP addresses and domain names
- **Used by registrars** GoDaddy, Fasthosts and many others
- **A free resource** accessible to anyone without cost
- **Reveals individuals and organisations** registrant type, address and contact details
- **Looked up online** whois.net, whois.com, who.is, whois.domaintools.com



© Billy Forrest

# Information stored in registration records

- **Registrant type** whether the holder is an individual or an organisation
- **Registrant's address** postal and registered address of the holder
- **Registrant's contact details** telephone, email and technical contacts
- **Registrar** the company through which the domain was registered
- **Registration dates** created, updated and expiry
- **Name servers** the authoritative DNS servers for the domain



© Billy Forrest

# WHOIS in the investigation

- **Valuable intelligence** WHOIS can hold valuable information about a target
- **Privacy protection** registrant details can be removed from the database
- **Varying depth** some websites retrieve more information than others
- **Cross-check** correlate WHOIS data with DNS and other open sources
- **Limits** anonymised and proxy-registered domains reveal little



© Billy Forrest

# The Domain Name System

- **A hierarchical, distributed database** shared among DNS name servers
- **Forward lookups** resolve a name such as www.pgittl.com to an address
- **Reverse lookups** map an address back to a name
- **Widely used** web browsers, email clients and utilities such as ping
- **Two-step resolution** root-level servers direct to top-level, then second-level servers



© Billy Forrest

# Structure, interpretation and analysis of DNS records

| Record | Purpose |
|---|---|
| A | Holds the fully qualified domain name → address mapping |
| CNAME | Alias; multiple services via one name or address (e.g. FTP and HTTP) |
| NS | Identifies the authoritative name servers for the domain |
| SOA | Start of authority — variety of information about the domain and its zone |
| MX | Specifies the mail server through which email should be delivered |
| TXT | Free-form text of any type (often SPF / DKIM) |
| PTR | Maps a network interface (IP) to a host name |
| HINFO | Information about the server's hardware and operating system |



© Billy Forrest

# DNS zone transfers

- **Replication** transfers DNS information to another DNS server
- **Full transfer** resource intensive and a lengthy process
- **Incremental transfer** less resource intensive and quicker
- **Facilitates attacks** transferred information can reveal the whole zone
- **Preventive measure** restrict transfers to authorised DNS servers



© Billy Forrest

# Dynamic DNS and fast-flux DNS

- **Dynamic DNS (DDNS)** maps dynamic IP addresses to domain names
- **Automation** DDNS providers automate the constant record updates
- **Security implications** phishing and malicious sites that constantly change IP
- **Hard to shut down** constantly moving targets are difficult to take offline
- **Fast-flux DNS** changes IP addresses every couple of minutes
- **Cybercriminal use** to hide their location and avoid detection



© Billy Forrest

# DNS information-gathering tools

| Tool | Typical command | Use |
|---|---|---|
| DNSRecon | dnsrecon -d [domain] | Enumeration and zone-transfer checks |
| Host | host -l [domain] | Simple lookups and zone listing |
| Nslookup | nslookup [domain] | Interactive DNS queries |



© Billy Forrest

DISCUSSION

# Why would an analyst routinely test whether a target's DNS zone transfer is open?

Think about what a successful AXFR reveals to an attacker versus what a single forward lookup reveals.

An open zone transfer hands the attacker the entire internal naming picture in one request.


© Billy Forrest

# How search engines work

1. **Web crawlers hunt** for new and updated content
2. **Copy pages** for the purpose of indexing
3. **Users search** the indexed data
4. **Garbage in, garbage out** search engines are only as good as the data collected and indexed



© Billy Forrest

# Advanced search operators

| Operator | Purpose |
|---|---|
| intitle: | Searches page titles for the term |
| inurl: | Searches URLs for the term |
| filetype: | Searches a certain file type |
| site: | Searches a specific website |
| Google Hacking Database (GHDB) | preconfigured operators tailored to identify sensitive information — exploit-db.com |



© Billy Forrest

# Online intelligence sources

- **Meta-search engines** aggregate results across multiple engines
- **Online directories** businesses by name, location and categorisation
- **People-search websites** find a person by name and location
- **Archived websites** free snapshots of historical web pages
- **Interactive maps** Google Maps / Earth — street view, terrain, live traffic
- **Social networking** Facebook, Twitter, LinkedIn — 'post first, think second'



© Billy Forrest

# theHarvester

- **Gathers from public sources** emails, subdomains, hosts, employee names, open ports and banners
- **Time delays** between requests to stay under the radar
- **Active enumeration** DNS enumeration, reverse lookups, TLD expansion
- **SHODAN integration** open ports and banners from the computer database
- **Output** save to XML and HTML with a basic graph and stats
- **Examples** theharvester -d microsoft.com -l 500 -b google



© Billy Forrest

# Extraction of document metadata

- **Hidden data** documents carry metadata beyond the visible content
- **Author and organisation** the name of the creator and their company
- **Dates and times** created, modified and printed
- **Application and paths** the software used and the machine / folder it came from
- **Embedded objects and revisions** hidden sheets, tracked changes, prior text
- **Tools** exiftool and similar metadata readers
- **Risk** metadata leaks information the author never intended to share



© Billy Forrest

# Community knowledge and threat reports

- **Threat reports** readily available — summaries of threats, key findings, concepts and forecasts
- **VirusTotal** multi-engine file and URL reputation checking
- **Open-source research** cheap, global, and tried and tested
- **Public wikis** and open security communities
- **Free investigation tools** Autopsy for disk analysis, Live View for imaging



© Billy Forrest

# Eliminating false positives

- **False dependence on commercial tools** a single vendor's verdict is not proof
- **Use multiple vendors' data** cross-check one engine's result against others
- **Recognise and analyse results yourself** do not outsource judgement to a scanner
- **Interpret reports** read the technical detail, not just the verdict



© Billy Forrest

# Open-source security resources

| Resource | Purpose |
|---|---|
| OWASP | Application security guidance and the Top Ten |
| OSS-Security Wiki | open-source security mailing list and wiki |
| OSSTMM | Open Source Security Testing Methodology Manual |
| Pentest Standard | structured penetration-testing methodology |



© Billy Forrest

CONSOLIDATION · GROUP C

# Group C at a glance

| Ref | Topic | Core idea |
|---|---|---|
| C1 | Registration records | WHOIS — who registered it, where, and when |
| C2 | DNS | Records, zone transfers, dynamic and fast-flux DNS |
| C3 | OSINT & web enumeration | Search operators, online sources, theHarvester |
| C4 | Document metadata | Hidden data inside files |
| C5 | Community knowledge | Threat reports, resources, false positives |


© Billy Forrest

## KEY TAKEAWAYS

- **WHOIS** registration records reveal registrant, registrar, dates and name servers
- **DNS records** each type — A, CNAME, NS, SOA, MX, TXT, PTR, HINFO — has a distinct role
- **DNS risks** zone transfers, dynamic DNS and fast-flux all enable attack and evasion
- **OSINT is layered** search operators, directories, archives, social media and theHarvester
- **Metadata leaks** documents carry hidden data the author never intended to share
- **Community knowledge** threat reports and multi-vendor checks eliminate false positives


© Billy Forrest

QUIZ

# confirmation quiz (Group C)

- Which DNS record identifies the authoritative name servers for a domain?
- What makes a fast-flux domain hard to shut down?
- What does the intitle: operator do in a Google search?
- Which tool gathers emails, subdomains and hosts from public sources?
- How do you best eliminate a false positive in malware analysis?

Answers in the confirmation quiz — aim for 60 percent before leaving.


© Billy Forrest

NEXT SESSION

# Next unit: Network Intrusion Analysis I

- Network traffic capture — Wireshark, tshark, tcpdump, SPAN ports and TAPs
- Data sources and network log sources — proxy, firewall, DNS, syslog and event logs
- Network configuration security issues — routing, DNS leakage and firewall evasion
- Designing a collection system and estimating capture requirements

Reading: Knowledge Group D source material.


© Billy Forrest